EDAM V3.4

EDAM 管理员使用手册

admin / dept_manager

企业全格式数字资产防泄密系统 · 版本 v3.4 · 2026-11-05

> 适用对象：admin 角色用户，或 dept_manager（部门管理员，权限子集） 文档版本：v3.4.1 / 2026-11-07 配套：普通员工使用手册（必读，避免误操作）

1. 管理员角色矩阵

角色	默认可见菜单	主要能力
admin	全部 8 个	全部功能 + RBAC + 备份恢复
dept_manager	7 个（无「角色权限」）	本部门视频/文档上传、编辑、审批、删除、查审计
auditor	6 个（无上传、审批、用户管理）	查所有审计日志 + 导审计报表
employee	5 个（无「角色权限」）	只读：看 + 播放 + 预览（不能上传 / 删除）

> 角色权限矩阵详细：见 2026-11-05-employee-readonly-role.md 与 doc/openapi.yaml 里各端点的 x-required-permission（46 条权限码）。

2. 快速导航

管理员专属菜单（在侧边栏底部）：

外发审批 审计日志 角色权限 ← RBAC 管理 设置 → 系统配置 Tab（仅 admin）

普通员工 + 部门管理员 + 审计员使用「角色权限」菜单会被 v-permission 指令自动隐藏（前端菜单过滤 + 后端 @PreAuthorize 双层防护）。

> v3.4 的角色变更： - employee（普通员工）收敛为只读 —— 不再能上传 / 删除； - dept_manager 补上了 video:delete / document:delete （原先能上传却删不掉自己传的东西）。 权限是数据（ sys_role_permission 表），不是代码 —— 在「角色权限」页勾两下 就能改一个角色能干什么，代码里没有任何东西会“编译报错”提醒你。 改完请跑一遍抽查 SQL 确认（见 §14）。

3. RBAC 用户与角色管理（admin 专属）

入口：左侧「角色权限」

3.1 4 个 Tab

Tab 1: 用户管理

字段	说明
用户名	登录名（唯一）
工号	员工号（E，唯一）
姓名	真实姓名
邮箱	通知邮箱
状态	active / disabled / locked

按钮： - 新增用户：弹窗填 username / password（≥6位）/ 工号 / 姓名 / 邮箱 - 编辑：改姓名 / 邮箱 - 重置密码：重置后必须 must_change_password=true（下次登录强制改密） - 分配角色：弹窗多选（employee / dept_manager / auditor / admin，可多选） - 删除（软删除 = status=2）：admin 自身不能删（按钮 disabled 防误操作） - Excel 导入：批量导入用户 + 角色绑定（详见 §3.2）

Tab 2: 角色管理

字段	说明
角色代码	admin / dept_manager / employee / auditor / 自定义
角色名	显示名
权限数	该角色拥有的权限码数量
权限代码	详细列表（tag 显示）

按钮： - 新建角色：定义 code + name + 选权限（弹窗里按 resource_type 分组的 el-checkbox-group） - 编辑：调权限集（admin 自带 ：不可改；自定义角色可改） - 删除：软删除（is_system=true 的不能删）

Tab 3: 权限目录（只读）

所有 46 条权限码列表，按 resource_type 分组展示。 每条权限码带一个 `action` 字段（read / upload / edit / delete / download / print / share / approve / manage / audit_export）—— 这个字段是普通员工只读基线的判据。

Tab 4: 我的角色

当前登录用户拥有的角色。

3.2 Excel 批量导入用户

「用户管理」Tab → 「Excel 导入」按钮。

模板格式：username / employee_no / real_name / email / password / role_codes 示例：zhangsan / E000020 / 张三 / zhangsan@example.com / Init@123 / employee

校验规则： - username 必填 - employee_no 必填且匹配 E - password ≥ 6 位（缺省 Init@123） - role_codes 用逗号分隔多个 role code

不覆盖原用户：工号已存在则跳过并记入 errors 列表

4. 外发审批（dept_manager / admin 可见）

入口：左侧「外发审批」

4.1 业务场景

员工把受控文档发到外部： 1. 员工提交外发申请 2. 部门管理员审核 3. 同意 → 颁发外发链接（带过期 token） 4. 接收方点链接 → 在水印保护下下载

4.2 列表字段

字段	含义
申请 ID	数字
文档名	哪个文档
申请人	工号 + 姓名
接收方	邮箱 / 组织
理由	业务说明
过期时间	链接失效时间
状态	pending / approved / rejected / expired
创建时间	申请时间

4.3 审批操作

- 同意：弹窗确认 → 生成外发链接 → 记录 approved_at + approver_id
- 驳回：必填理由 → 记录 rejected_at + reason
- 撤销（已批准的）：撤销后链接立即失效

每次操作写 audit_log：operation_type=distribution:approve / distribution:reject / distribution:revoke

4.4 链接参数

外发链接格式：https://EDAM/external/token?doc_id=N - token 包含：document_id + recipient + expires_at + 单次使用标志 - 后端验证 token 后返回文件流（带水印） - 接收方只能用一次 + 必须浏览器内打开

5. 审计日志

入口：左侧「审计日志」

5.1 列表字段

字段	说明
时间戳	操作发生时间（CST）
操作者	user_id
工号	JOIN sys_user 拼
操作类型	login / logout / preview / create / update / delete / assign_role 等
资源类型	auth / user / role / video / document / distribution
资源 ID	具体资源的 id
结果	success / failure / denied
IP	X-Forwarded-For 优先，否则 RemoteAddr
User-Agent	浏览器 / 客户端
详情	人读字符串

5.2 过滤

支持按 操作者 / 操作类型 / 时间段查询。

5.3 导出

「审计日志」Tab → 「导出」按钮 → 生成 Excel 文件（带查询条件过滤的结果集），MFA 二次校验。

> audit:audit_export 权限控制 — 普通员工看不到导出按钮。

6. 备份与恢复（admin 专属）

入口：左侧「设置」→ 「系统配置」Tab → 「备份」

6.1 触发备份

- 选备份类型（full / incremental）
- 填 MFA 动态令牌
- 点「触发备份」→ 后端异步执行
- 返回 task_id

6.2 恢复

- 选备份 ID
- 填 MFA + 审批 token + confirm=true
- 点「恢复」→ 后端先停服务 → 恢复 DB → 恢复 MinIO → 重启

二次确认 是合规要求：MFA 证明是本人 + 审批 token 证明有上级授权。

7. 视频 / 文档高级管理（admin / dept_manager）

普通员工只「看 + 播放 + 预览」（v3.4 起不能上传 / 删除），admin 额外能：

7.1 视频

- 删除：硬删除
- 批量删除：多选 + 一次性删除
- 批量权限：跨用户 / 跨部门分配视频访问权（video_permission 表）
  - 列：用户 ID / 部门 ID / 角色 code / 操作（view / download / share）
  - 过期时间（expires_at）

7.2 文档

同视频，还有「预览日志」可查（谁看了什么、什么时候）。

7.3 密级：服务端会裁决，不是你说了算（v3.4.1 起）

上传时你填的密级是申请值，最终落库的是服务端裁决后的值：

> 最终密级 = max(服务端基线, 你填的值) —— 你可以往严里选，不能往松里选。

服务端基线来自三处：文件名关键词、文件大小、上传者所在部门。

现象	说明
你填 L1，系统按 L3 存	文件名 / 部门命中了更严的规则；前端会弹提示告知实际密级
填了 L9 之类的非法值	直接 400 拒绝，不会像从前那样悄悄当成 L1

现象	说明
想把一份被自动判严的文件调松	走下面的人工调整，有审计留痕

> L4 绝密只能由人显式声明 —— 自动识别最高只到 L3（机密）。 否则一个 6GB 的培训视频会被自动判成谁也看不见的资产。 确实需要 L4 时，在上传时直接填 L4。

人工调整密级（需要 `classification:manage` 权限，默认只有 admin 有）：

```
PATCH /api/v1/classification/videos/{video_id}

PATCH /api/v1/classification/documents/{doc_id}

Content-Type: application/json



{ "classification_lv": "L2", "reason": "该文件已脱敏，可降为内部" }
```

- `reason` 必填 —— 没有理由的降级等于审计形同虚设
- 每次调整都写 `data_classification_audit`（谁 / 何时 / 从什么改成什么 / 为什么）
- 这是唯一能把密级往低调的路径 —— 上传时的裁决只允许往严调

注意：自动识别是启发式，不是内容分析。文件名和大小都由客户端可控， 把它们当基线只是“便宜的启发式”；真正的内容级识别需要文档分析引擎，尚未实现。 部门是当前唯一不可伪造的基线信号。

8. 安全管理

8.1 重置用户密码

用户管理 → 选用户 → 「重置密码」按钮 → 弹窗输入新密码 → 保存。 - 系统自动 must_change_password=1（下次登录强制改） - 写 audit reset_password

8.2 撤销密钥（紧急吊销）

用户管理 → 选用户 → 「紧急吊销」按钮 → 该用户所有 access_token + refresh_token 立即失效（清 Redis + DB sys_session.revoked=1） - 写 audit revoke_keys

适用场景：员工离职、密码泄露、离职交接期。

8.3 角色权限热更新

改了某用户的角色后，该用户需要重新登录才生效（token 里的 roles claim 是登录时快照）。 - 例外：admin 操作 assign_roles 后，建议在用户档案加 TODO 通知他重新登录

9. 系统配置

左侧「设置」→ 「系统配置」Tab（仅 admin）

9.1 当前可配项

配置	默认	含义
是否强制 MFA	true	L3+ 资源登录必填动态令牌
会话超时（秒）	600	token TTL
文件大小上限（视频 MB）	8192	超过上传被拒（8GB）
文件大小上限（文档 MB）	50	同上
密码最小长度	6	少于这个数注册被拒
登录失败锁定阈值	5	连续 5 次后锁定 30 分钟
是否记录 IP	true	audit 写 ip / ua 字段

修改后点「保存」→ 重启后端生效（部分配置需要重启）。

10. 监控与运维

10.1 Prometheus 指标

后端 Spring Boot Actuator 暴露 /actuator/prometheus： - jvm_memory_：JVM 内存 - http_server_requests_seconds：API 延迟 - rabbitmq_：MQ 队列长度 - worker_tasks_processed_total：Worker 处理数

接入 Prometheus + Grafana 可视化。

10.2 健康检查

/actuator/health/liveness 和 /actuator/health/readiness 用于 K8s 探针。

11. 数据库操作（最高权限，慎用）

直接连 MySQL 容器（docker exec -it edam-mysql mysql -uroot -p edam）：

表	用途
sys_user	用户基本信息
sys_role	4 个预置角色

表	用途
sys_user_role	用户-角色关联
sys_permission	45 条权限码
sys_role_permission	角色-权限关联
sys_session	登录会话
operation_log	审计日志（永远 append-only）
video_resource / doc_resource	资产元数据
audit_log	v3.2 V-1 新增，记录所有 RBAC 操作

⚠ operation_log 和 audit_log 是合规要求，永远不要 DELETE / UPDATE。误操作时只能 APPEND 修正条目。

12. 故障排查

12.1 用户登录后看不到菜单

→ 检查 sys_user_role 表 + sys_role.is_system + 角色是否被软删

12.2 用户上传后看不到自己上传的视频

→ 检查 video_resource.deleted_at IS NULL + classification_lv 是否在用户可看范围内

12.3 L4 视频上传失败

→ 检查文件大小（<8GB）+ 后端 L4 权限白名单

12.4 审计日志 IP 是 127.0.0.1

→ 反向代理没传 X-Forwarded-For 头 → 后端 application.yml 加 server.forward-headers-strategy: framework → 生产必须配代理

12.5 前端 401 跳不到 /login

→ 清 Vite 缓存 + Ctrl+Shift+R 硬刷 → 检查 Console 是否有 [global] / [global-xhr] 日志（说明 wrapper 已加载）

12.6 RBAC 接口 403 Forbidden

→ 用户的 token 里没那个权限 → 重新登录让 token claim 刷新（或者 admin 给该用户分配权限）

13. 紧急响应流程

13.1 密码泄露

1. 立即 PUT /users/{id}/revoke-keys 吊销该用户所有 token
2. PUT /users/{id} 修改密码
3. audit_log 查所有最近登录的 IP / UA
4. 通知 IT 升级 RBAC 规则

13.2 离职员工账号

1. DELETE /users/{id}（软删除 = status=2 禁用，保留审计）
2. 不要物理删除！审计 + 责任追溯依赖这条
3. 如要清 token：POST /users/{id}/revoke-keys

13.3 数据泄露事件

1. audit_log 查 operation_type='preview' + 时间段 → 找可疑用户
2. audit_log JOIN sys_user → 拿到可疑员工
3. 追溯具体文档 / 视频 → 走公司安全事件流程

14. 升级与变更

新功能 / 修复的变更记录：modify/2026-08-12-v3.1修复记录.md 起 + 后续日期的 .md。

升级前必读： 1. 备份 DB：docker exec edam-mysqldump > backup_DATE.sql 2. 备份 MinIO 桶：mc mirror edam-videos backup-videos 3. 读变更记录 → 看有没有破坏性变更 4. 跑 Flyway 自动迁移（./start.sh spring-boot:run 启动时自动跑） 5. 端到端测试核心路径

14.1 改完权限后必做：抽查 SQL

权限是数据，改错了不会报错 —— 只能查出来。在生产库跑：

```
-- 普通员工的权限应当**全部是只读**（期望 10 行，action 全是 'read'）

SELECT r.code AS role_code, p.code AS perm_code, p.action

FROM sys_role_permission rp

JOIN sys_role r       ON r.id = rp.role_id

JOIN sys_permission p ON p.id = rp.permission_id

WHERE r.code = 'employee'
```

```
ORDER BY p.code;
```

只要结果里出现 `action` 不是 `read` 的行，就是配错了 —— 先在「角色权限」页把多余的勾去掉。

> 改了权限还要让用户重新登录：JWT 里的权限码是登录时签发的， 改完数据库后旧 token 仍带旧权限，要等 token 过期或用户重新登录才生效。

15. 联系

类别	邮箱
一般 IT 支持	support@edam.local
安全事件	security@edam.local（24h 响应）
角色 / 权限配置	rbac-admin@edam.local
数据迁移	data-migration@edam.local

SLA：紧急 2h，普通 8h